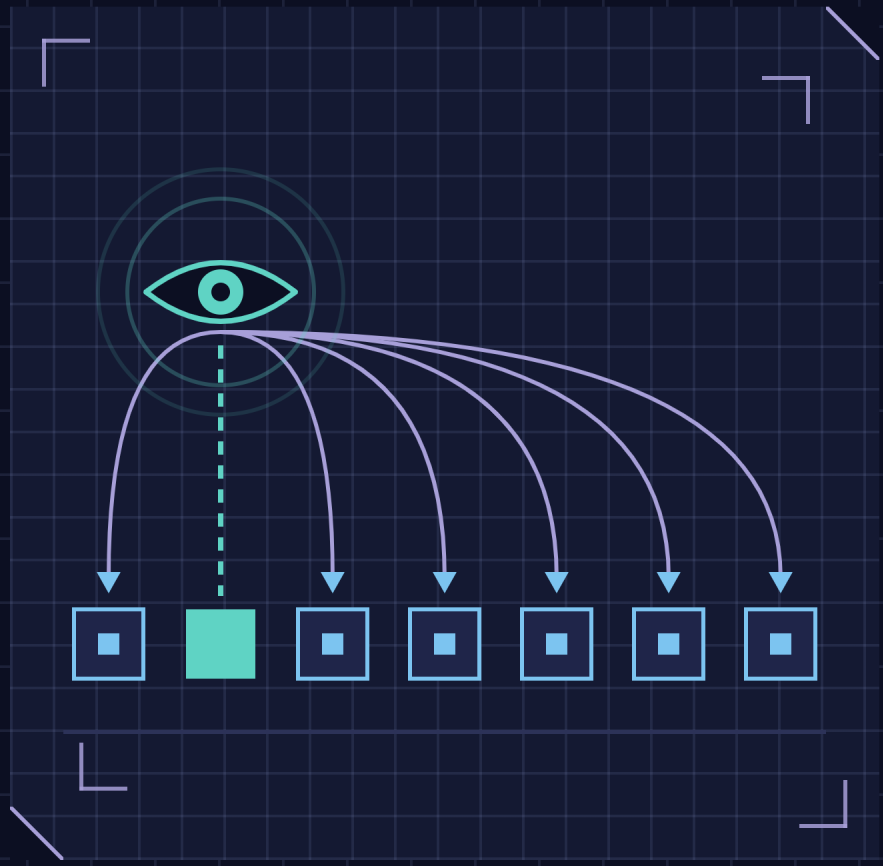
Розвідка кіберзагроз у складчину

Навіщо Україні спільний ISAC для критичної інфраструктури — і як нейтральна сторона робить обмін даними про кіберзагрози безпечним, швидким і якісним



ЖОВТЕНЬ 2026

КОРОТКО

Головне за одну хвилину

Проблема	Реагувати на інциденти вміємо, але розвідки, що зводить сигнали й підказує рішення, немає — як і безпечного каналу обміну.
Рішення	Спільний міжгалузевий ISAC для критичної інфраструктури: нейтральний оператор, безпечний обмін і розвідка для всіх учасників.
Економіка	Внесок ≈ $4,5–30 тис. на рік за розміром. Своя розвідка — від $130 тис., тож для більшості альтернатива ISAC — жодної розвідки.
Пропозиція	Разом заснувати ISAC: шукаємо організації-засновників і публічного лідера.

I

Проблема

Загрози спільні, а захищаємося поодинці

ЦЕ ВЖЕ СТАЛОСЯ · ГРУДЕНЬ 2023

Атака на одного – проблеми в багатьох галузях



Банки
До 30% POS-терміналів ПриватБанку без зв’язку; збої в Ощадбанку

Громадська безпека
Збої сирен повітряної тривоги в Сумах

Міське господарство
Вуличне освітлення вимикали вручну

Енергетика
Контакт-центри ДТЕК недоступні

Інші оператори
Навантаження на Vodafone і lifecell — у рази

Джерела: Texty · Фокус · розбір — у додатках

СПРАВЖНІЙ РОЗРИВ

Реагування є — розвідувального шару немає

БРАКУЄ **Розвідка**	Вимоги	Злиття сигналів	Продукти для керівництва	Зворотний зв’язок
УЖЕ Є **Реагування**	Розслідування й форензика	Аналіз ШПЗ і атрибуція	IOC і TTP від CERT-UA	Канали обміну з державою

Після «Київстару» й атаки на реєстри Мін’юсту технічних уроків для інших оприлюднено небагато: знахідки розслідувань не стають знанням галузі.

БРАК КОНТЕКСТУ

Рішення доводиться ухвалювати наосліп

«Це шкідливий індикатор чи ні?»

Невідомо, чи бачили його в інших і з якою кампанією він пов’язаний.

«Нас зламали чи ні?»

Без знання технік нападника важко зрозуміти, що шукати і де.

«Які ризики нам врахувати?»

Немає картини, хто й чим атакує галузь, — пріоритети й бюджет наосліп.

Відповіді часто вже є в сусідніх організаціях — але немає безпечного каналу, щоб ними поділитися.

ЧОТИРИ БАР'ЄРИ

Чому відповідями не діляться

Страх

Репутація, юристи, перевірки: простіше промовчати.

Недовіра

Чи не дійде моє до конкурента чи в новини?

Повільність

Кожне повідомлення погоджують — воно застаріває.

Шум

Загальні бюлетені: незрозуміло, що стосується вас.

У підсумку кожен шукає відповіді сам, а нападник знову й знову використовує ту саму техніку.

II

Довірене коло

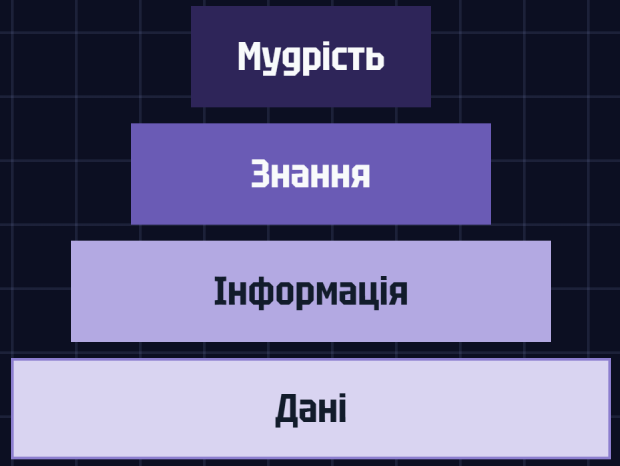
Що таке розвідка, ISAC і чому йому можна довіряти

ПРОСТИМИ СЛОВАМИ

Що таке розвідка кіберзагроз

ВИЗНАЧЕННЯ

Знання про те, хто, як і навіщо може атакувати вашу організацію, подане так, щоб ухвалити рішення.



Рішення: блокуємо адреси, перевіряємо VPN

Група атакує нашу галузь — ризик високий

Ті самі адреси з країною й часом

Список підозрілих IP-адрес

91% → 26% CISO вважають розвідку цінною, але лише 26% кажуть, що вона впливає на рішення. **ISAC піднімає дані багатьох організацій до рівня рішень.**

Детальніше — CTI101 · приклад — Kraven Security · опитування — SANS CTI Survey 2026

ГОЛОВНА ДУМКА · НЕЙТРАЛЬНИЙ ЦЕНТР

Довіру будує нейтральна сторона



Нейтральний оператор — центр довіри
Громадська організація: через неї йдуть усі повідомлення, і вона не конкурує з жодним учасником.

Учасники
Діляться через оператора за спільними правилами — не знаючи, хто саме повідомив.

Партнери — за угодами
CERT, постачальники розвідки, ISAC інших країн: обмін в обидва боки, без сирих даних.

Регулятори — поза колом
Лише знеособлена статистика й тренди.

«Залізний» трикутник кібербезпеки



ЯК ЦЕ ПРАЦЮЄ · ЦЕНТР ЗЛИТТЯ РОЗВІДКИ

Від сигналу одного — до захисту всіх

01 Збір

Сигнали учасників, партнерів, комерційних і відкритих джерел

02 Аналіз

Перевіряємо, корелюємо, додаємо галузевий контекст

03 Дія

Попередження, брифінги для керівництва й IOC — усім учасникам

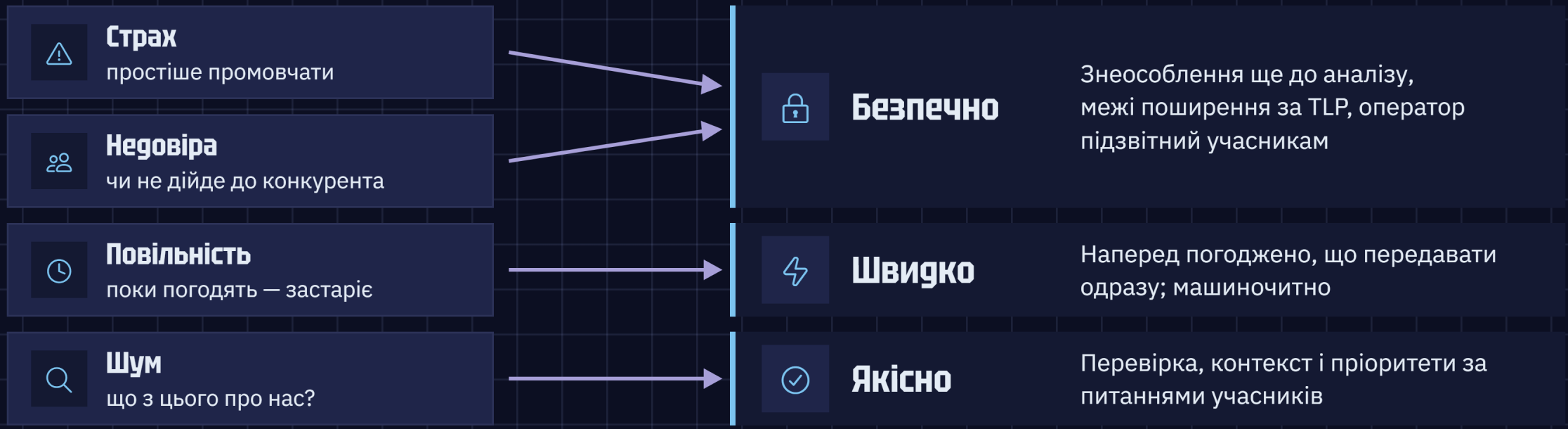
04 Відгуки учасників задають пріоритети наступного циклу

Сигнал однієї організації робить безпечнішою всю екосистему.

Центр злиття, а не ще один постачальник; поширення — STIX/TAXII, MISP · за CI-ISAC, Prospectus (2025)

ВІДПОВІДЬ НА ЧОТИРИ БАР'ЄРИ

Безпечно, швидко, якісно



Ніколи не передаємо: персональні дані, внутрішні IP й назви систем, деталі захисту.

Джерела: CI-ISAC, Information Sharing Guidelines · ENISA ISAC in a Box

III

Що отримують учасники

Продукти, питання правління, ціна й досвід інших

УМОВНИЙ ПРИКЛАД

Як виглядає попередження ISAC

TLP:AMBER ПОПЕРЕДЖЕННЯ ISAC Впевненість: висока

Фішинг від імені постачальника ПЗ

Що сталося	Листи «про оновлення ліцензії» ведуть на підроблений портал; крадуть облікові дані VPN.
Кого стосується	Енергетика й телеком: за 48 годин повідомили 3 учасники, джерела знеособлено.
Індикатори	Домени й хеші — машиночитно в платформі; MITRE ATT&CK T1566.002.
Що зробити	Заблокувати індикатори, перевірити журнали VPN за 14 днів, попередити бухгалтерію.

Одна сторінка — і команда знає, що робити сьогодні.

TLP:AMBER — лише своїй організації та її клієнтам, тим, кому потрібно знати.

Умовний приклад; позначки — за FIRST TLP 2.0

ПРОДУКТИ ЗА РІВНЯМИ ЗРІЛОСТІ

Що отримує учасник — і ціна самотужки

РІВЕНЬ 1 · ПОЧАТКОВА

- Курований потік індикаторів
- Розвідка щодо вразливостей
- Витоки й інфостілери
- Термінові попередження

до $10 тис.
самим · 1 аналітик-початківець

РІВЕНЬ 2 · СЕРЕДНЯ

- Щотижневий огляд кампаній
- Розвідка щодо фішингу
- Пакети для полювання
- Аналітик на запит

$50–150 тис.
самим · 2 фахівці й керівник

РІВЕНЬ 3 · ЗРІЛА

- Піврічний огляд загроз галузі
- Брифінги для керівництва
- Обмін з партнерами

$200–400 тис.
самим · 3 фахівці й керівник

З розвитком ISAC — продукти всіх трьох рівнів, без власної команди.

Бюджети без зарплат; повна ціна — на слайді 18 · рівні — J. Visser, CTI Use Cases (2023)

Від питання правління – до розвідки

БАНКИ

Де ми найбільше втрачаємо на шахрайстві й куди спрямувати бюджет захисту?

ПИТАННЯ РОЗВІДКИ (GIR)

Які нові схеми шахрайства й фішингу проти клієнтів українських банків з’явилися за місяць?

ПРОДУКТ ISAC

Щомісячний огляд нових схем шахрайства й фішингу

ЕНЕРГЕТИКА

Що може зупинити генерацію чи постачання – і що захищати першим?

ПИТАННЯ РОЗВІДКИ (GIR)

Яке шкідливе ПЗ для SCADA й промислових протоколів виявляли в Україні та Європі за рік?

ПРОДУКТ ISAC

Бюлетень загроз для АСУ ТП і детекти для ОТ-мереж

IT

Чи не станемо ми точкою входу до клієнтів – і чим це загрожує контрактам?

ПИТАННЯ РОЗВІДКИ (GIR)

Які групи атакували українських IT-постачальників і MSP як шлях до клієнтів КІ за рік?

ПРОДУКТ ISAC

Огляд атак через постачальників і MSP для правління

Питання правління → конкретне питання з періодом і масштабом → продукт · більше прикладів — у додатках

ЦІННІСТЬ І ЦІНА · ДЕМОНСТРАТИВНИЙ РОЗРАХУНОК

Альтернатива ISAC — не своя команда, а її відсутність



Багаті ринки можуть дозволити, щоб кожен будував розвідку сам. Нам вигідніше скластися — і отримати те, що поодинці недосяжне.

Демонстративно · зарплати — DOU, літо 2026 · ціни джерел — UnderDefense

ДОСВІД ІНШИХ

Що працює і чого уникати

АВСТРАЛІЯ · CI-ISAC — ЦЕ ПРАЦЮЄ

Міжгалузева спільнота за три роки

150+
організацій-учасників

700+
розвідувальних попереджень

11
секторів КІ — усі

- Неприбуткова, керована учасниками; найбільша користь — зекономлені години
- Внески ≈ $1–31 тис. на рік залежно від доходу; таблиця — у додатках

США · MS-ISAC — ЧОГО УНИКАТИ

ISAC на чужому бюджеті



учасників після припинення федерального фінансування

Внески учасників — з першого дня; гранти — доповнення.

Джерела: CI-ISAC, Prospectus (червень 2025) · CI-ISAC, Membership · Cybersecurity Dive · StateTech

IV

Як долучитися

Участь, дорожня карта і наступний крок

УЧАСТЬ

Як долучитися і що це вимагає

01 — Заявка
Анкета, контактна особа, базова кібергігієна

02 — Перевірка
ISAC перевіряє, рада погоджує вступ

03 — Договір
Конфіденційність, TLP, внески

04 — Старт
Підключення, онбординг, робоча група

ПЕРШІ 90 ДНІВ · ЩО ОТРИМУЄТЕ

- Платформа й щоденні попередження
- Індикатори для імпорту в SIEM
- Перший галузевий брифінг для керівництва

Обмін — це взаємність: контактна особа й кілька годин на тиждень, висновки з власних інцидентів і відгуки на попередження.

Платять по-різному — голос однаковий

ВЕЛИКА ОРГАНІЗАЦІЯ

≈ $30 тис.

Системні банки, нацоператори, енергетика, IT від 1000 людей

СЕРЕДНЯ ОРГАНІЗАЦІЯ

≈ $13,5 тис.

Обленерго, регіональні банки, логістика, IT 200–1000

МАЛА ОРГАНІЗАЦІЯ

≈ $4,5 тис.

Лікарні, громади, малі постачальники й підрядники

Ядро послуг однакове для всіх рівнів — і голос теж: один учасник, один голос.

Демонстративно: рівень — за кількістю працівників чи доходом · модель — за CI-ISAC, Membership · запобіжники в статуті — у додатках

ДОРОЖНЯ КАРТА

Чотири фази до зрілого ISAC

01
Побудова
- Ініціативна група, статут і TLP
- Оператор і платформа

◆

02
Робота
- Регулярний обмін і довіра
- Перші продукти — пілот

◆

03
Оцінка
- Вплив: швидше виявлення
- Бізнес: менші втрати й простої

◆

04
Розвиток
- Нові учасники й галузеві групи
- Зв’язки з CERT та іншими ISAC

Запускає нейтральна команда фахівців з CTI (ГО), а керують учасники.

◆ — перехід, коли виконано базові вимоги попередньої фази · ENISA ISAC in a Box · The member-driven model

ДЕ МИ ЗАРАЗ

Що вже є і чого бракує

УЖЕ Є

Поради досвідчених ISAC
Досвід створення й щоденної роботи ISAC.

Місцеві консультанти
Українське право, ринок і специфіка КІ.

Готові моделі
ENISA ISAC in a Box і практика CI-ISAC.

Державні платформи обміну
ISAC доповнюватиме їх обміном між учасниками.

ПОТРІБНО

Публічний лідер
Людина, яка доведе ідею до кінця.

Команда оператора
5 людей: керівник, 3 аналітики, DevOps; плюс стажери й відряджені від учасників.

Організації-засновники
Критична маса: 12–15 для пілота — вони задають правила.

Стартове фінансування
Донори — на запуск, далі — внески учасників.

Наступний крок

Ми збираємо критичну масу організацій-засновників. Висловіть зацікавленість і залиште контакт — повернемося з пропозицією, щойно сформується ініціативна група. А зараз — питання й обговорення.

Іван Гокін

Технічний консультант ініціативи

linkedin.com/in/ivan-gokin



Додатки

Деталі для аналітиків, приклади інцидентів і відповіді на рідші запитання

ДОДАТОК · ЗА АБЕТКОЮ

Словничок термінів

ATT&CK	база тактик і технік нападників (MITRE)
CISO	керівник з інформаційної безпеки
GIR	постійні розвідувальні питання галузі
IOC	ознаки компрометації: IP, домени, хеші
MISP	відкрита платформа обміну індикаторами
OSINT	розвідка з відкритих джерел
SIEM, EDR	збір подій і захист робочих станцій
SOP	стандартна операційна процедура
TIP	платформа розвідки кіберзагроз
TTP	тактики, техніки й процедури атак
КІ	критична інфраструктура
CI/CD	конвеєр збирання й розгортання коду
DevOps	інженер інфраструктури й автоматизації
HMI	панель оператора промислової системи
ISAC	центр обміну інформацією про загрози
MSP, MSSP	керовані IT- і безпекові послуги
ОТ, АСУ ТП	промислові системи керування, SCADA
SOC	центр моніторингу кібербезпеки
STIX, TAXII	формат опису загроз і його доставка
TLP	позначки, кому можна передавати
ГО	громадська організація

ДОДАТОК · ДЛЯ АНАЛІТИКІВ

Технічна кухня обміну

Позначки

TLP 2.0 — кому можна; PAP — що можна робити з даними.

Якість

Рівень впевненості, надійність джерела, строк життя індикатора.

Зворотний зв’язок

Хибне спрацювання чи «бачили в себе» — оцінка індикатора.

Спільнота аналітиків

Закритий канал, спільні розбори, навчання й наставництво.

Формати й доставка — на слайді про конвеєр · стандарти: OASIS STIX/TAXII, FIRST TLP 2.0, MISP, MITRE ATT&CK

ДОДАТОК · ПОШИРЕНІ ПИТАННЯ · ДЕТАЛЬНО – НА НАСТУПНИХ СЛАЙДАХ

Поширені питання – коротко

«Навіщо ISAC, якщо вже є державний CERT?»
CERT реагує на інциденти; ISAC — обмін між рівними. Вони доповнюють одне одного (слайд 11).

«Чому не доручити обмін галузевій асоціації?»
Асоціація розвиває галузь і говорить із владою; ISAC — щоденний обмін фахівців з безпеки різних галузей.

«Чи не захоплять ISAC найбільші учасники?»
Статут це унеможливлює: один учасник — один голос, до 25% внесків від одного, незалежна команда оператора.

«Чи не порушимо ми закон, обмінюючись даними?»
Лише технічні дані, без персональної й комерційної інформації; правила й відповідальність — в угоді.

«Чи дізнається регулятор про наші інциденти?»
Обов’язкові повідомлення — як і раніше; від ISAC державі йде лише знеособлене й за угодою.

«Що буде, якщо зламають сам ISAC?»
Його захищають як критичну систему: перевірка учасників, мінімум даних, план на випадок компрометації.

«Навіщо ISAC, якщо вже є чат у месенджері?»
Чат не дає перевірених учасників, захисту, перевірки якості й історії — ISAC це забезпечує.

«Навіщо ділитися інформацією з конкурентами?»
Нападники й ланцюги постачання спільні, тож безпека — не предмет конкуренції. Джерело знає лише оператор.

СУМНІВ 1

«Навіщо ISAC, якщо вже є державний CERT?»

	Державний CERT	ISAC
Хто створює	Держава	Самі учасники
Головне завдання	Реагування й координація на національному рівні	Обмін і аналіз між колегами
Напрям обміну	Вертикально: повідомлення про інциденти	Горизонтально: між рівними
Що передають	Те, про що треба повідомити	Ще й ранні ознаки, про які повідомляти не треба
Фокус	Уся країна	Питання й пріоритети учасників

ISAC часто діляться дієвою інформацією швидше за державних партнерів — National Council of ISACs

СУМНІВ 2

«Чому не доручити обмін галузевій асоціації?»

	ISAC	Галузева асоціація
Цільова аудиторія	Фахівці з кібербезпеки, CISO	Галузеві фахівці, вище керівництво
Зона відповідальності	Обмін та аналіз інформації про кіберзагрози	Розвиток галузі
Межі	Усі галузі критичної інфраструктури	Одна галузь

«Чи не захоплять ISAC найбільші учасники?»

Один учасник – один голос

Вага в рішеннях не залежить від розміру внеску.

Платять по-різному, отримують однаково

Внесок — за розміром, але не більше 25% від одного учасника; ядро розвідки однакове.

Обмеження місць у правлінні

Одне місце на організацію; квоти для галузей і для середніх і малих.

Незалежний оператор

Команду наймає ГО-оператор; найбільші учасники її не делегують.

Ротація

Голови робочих груп і правління змінюються за графіком.

Прозорість

Статут і правила опубліковані; щорічний звіт для всіх учасників.

Пропоновані практики врядування; внески й однакові базові послуги — CI-ISAC, Membership

СУМНІВ 4

«Чи не порушимо ми закон, обмінюючись даними?»

Лише технічні дані

Індикатори й техніки, без персональних даних.

Угода учасника

Конфіденційність, TLP, обмеження відповідальності.

Без цін і ринків

Немає комерційної інформації — немає й антимонопольних питань.

Юристи з першого дня

Шаблони угод і позиція щодо законодавства.

ЯК У США

Закон CISA 2015 захищає від відповідальності за обмін; антимонопольні органи: належно організований обмін «не має викликати питань».

В УКРАЇНІ

Закон декларує обмін інформацією про загрози, але не регулює його між компаніями — тож правила фіксуємо в угоді.

Не є юридичною консультацією · джерела: CISA 2015 · DOJ і FTC, 2014 · Закон № 2163-VIII

СУМНІВ 5

«Чи дізнається регулятор про наші інциденти?»

Обов’язкові повідомлення – як і раніше

ISAC не скасовує обов’язків перед регуляторами й CERT.

Державі – лише знеособлене

За угодою з CERT і лише те, що погодили учасники.

Запити – лише за законом

Дані конкретного учасника — тільки за законною процедурою.

Правила знають усі

Політика передачі даних — частина угоди учасника.

Довіра тримається на передбачуваності: учасник наперед знає, що й кому може піти.

СУМНІВ 6

«Що буде, якщо зламають сам ISAC?»

Перевірка учасників

Вступ за рекомендацією; перевірка організації й контактних осіб.

Мінімум даних

Лише знеособлене; без сирих журналів; строк зберігання.

Розмежування доступу

Ролі, TLP, сильна автентифікація, журналювання дій.

План на компрометацію

Відкликання доступу, сповіщення учасників, перевірка.

ISAC — ціль для нападників, тож його захищають як критичну систему з першого дня.

СУМНІВ 7

«Навіщо ISAC, якщо вже є чат у месенджері?»

	Чат у месенджері	ISAC
Хто всередині	Невідомо: хтось додав, хтось переслав	Перевірені учасники за угодою
Захист	Особисті телефони й акаунти	Захищена платформа й TLP
Якість	Пересилки без перевірки й контексту	Перевірка, контекст, пріоритети
Пам'ять	Тоне в стрічці за день	База й машиночитні індикатори
Відповідальність	Нічия	Оператор підзвітний учасникам

Ризики неформального обміну — CI-ISAC, Prospectus (червень 2025)

Один ISAC, галузеві робочі групи



Галузеві групи · перелік відкритий · у США позагалузеві спільноти обміну називають ISAO

Для всіх

Розвідка, попередження й брифінги — незалежно від галузі: атаки через постачальників перетинають галузі.

У групах

Галузеві пріоритети, специфічні загрози й технології — наприклад, АСУ ТП в енергетиці.

ДОДАТОК · НАСТУПНИЙ ЕТАП

Згодом: конвеєр розвідки для всіх

На вході: сигнали учасників, CERT, комерційні й відкриті джерела

01
Відбір
За загальними розвідувальними вимогами учасників

02
Перевірка
Правдивість, якість, несуперечність

03
Кореляція
Зв’язки між сигналами різних учасників

04
Пакування
У стандартний формат STIX

05
Доставка
Через TAXII — автоматично в засоби захисту учасників

STIX і TAXII — простими словами
STIX — опис загрози спільною мовою засобів захисту. TAXII — сервер і протокол, що віддає ці описи пачками (колекціями) за підпискою.

Людина в контурі
Спірне й важливе вирішують аналітики, рутину — автоматика.

ШІ як підсилювач аналітиків

01 Джерела
Учасники, партнерські й комерційні фіди, OSINT, CERT

→

02 Збір за вимогами
Збір під розвідувальні вимоги учасників (GIR)

→

03 Перевірка
Дедуплікація, надійність, TLP, знеособлення

04 ШІ-обробка
Звіти → STIX, витяг IOC і TTP, ATT&CK, чернетки продуктів

→

05 Сховище й кореляція
Платформа обміну й граф знань для аналітика

→

06 Продукти й доставка
Каталог і SOP; TAXII, портал, пошта, захищений чат

Людина в контурі: ШІ готує — аналітик перевіряє й випускає. Відгуки учасників коригують вимоги збору.

Безпека: захищене середовище, ISO 27001, розмежування доступу, журнали; чутливі дані не потрапляють у навчання моделей ШІ.

Спрощено за ідеєю AI-first CTI architecture (ThreatNG) · стандарти: STIX/TAXII, MITRE ATT&CK

ДОДАТОК · ЯК ВИТРАЧАЄМО ВНЕСКИ

Пріоритети бюджету й підтримка ззовні

ПРІОРИТЕТИ БЮДЖЕТУ

1. **Люди**
   Аналітики й DevOps — серце розвідки
2. **Платформа розвідки (TIP)**
   Збір, перевірка й поширення індикаторів
3. **Решта спроможностей**
   Джерела, хмара, безпека, бекофіс

ПІДТРИМКА ЗЗОВНІ, ЯКУ ВІТАЄМО

- Ліцензії платформи й доступ до джерел
- Гранти на запуск і перші роки
- Обладнання й хмарні кредити
- Навчання й сертифікації команди
- Пентест, аудит і ISO 27001
- Юридичний супровід і шаблони угод

Червоні лінії: без впливу на пріоритети, без доступу до даних учасників; уся підтримка — у звіті.

Як платять за ISAC в Австралії

РІЧНИЙ ДОХІД, AUD	ВНЕСОК НА РІК, AUD
> 5 млрд (> $3,5 млрд)	**45 000** (≈ $31 500)
1–5 млрд (≈ $0,7–3,5 млрд)	**35 000** (≈ $24 500)
0,5–1 млрд (≈ $350–700 млн)	**27 500** (≈ $19 250)
250–500 млн (≈ $175–350 млн)	**20 000** (≈ $14 000)
100–250 млн (≈ $70–175 млн)	**15 000** (≈ $10 500)
50–100 млн (≈ $35–70 млн)	**10 000** (≈ $7 000)
10–50 млн (≈ $7–35 млн)	**5 000** (≈ $3 500)
< 10 млн (< $7 млн)	**1 500** (≈ $1 050)

$1–31 тис.
на рік з однієї організації

Ядро – однакове
Ті самі базові послуги для всіх.

Знижки 15-30 %
Неприбутковим і держмедзакладам.

Це приклад Австралії: в Україні модель і внески, найімовірніше, будуть іншими.

Перехідні внески CI-ISAC на 2026 рік · CI-ISAC, Membership · у дужках — орієнтовно в доларах США за курсом ≈ 0,70 $ за 1 AUD (жовтень 2026)

ДОДАТОК · БАНКИ

Банки: розвідка проти атак і шахрайства

ПРИКЛАДИ ЗАГАЛЬНИХ РОЗВІДУВАЛЬНИХ ВИМОГ ГАЛУЗІ (GIR)

01 Які групи атакували банки й платіжні сервіси України за останні 6 місяців і якими техніками?

02 Які нові схеми шахрайства й фішингу проти клієнтів українських банків з’явилися за останній місяць?

03 Які фішингові домени й підробні застосунки під бренди учасників зареєстровано за останні 7 днів?

04 Чи з’являлися облікові дані працівників чи клієнтів учасників у логах інфостілерів за останні 30 днів?

05 Які вразливості ДБО, процесингу чи ПЗ постачальників експлуатувались або мали публічний експлойт за 30 днів?

Окремо – шахрайство

- Фішингові домени, підробні сайти й застосунки
- Нові схеми соціальної інженерії
- Обмін ознаками шахрайства між банками

ДЛЯ ПРАВЛІННЯ

Де ми найбільше втрачаємо на шахрайстві й куди спрямувати бюджет захисту?

Плюс базові продукти всіх трьох рівнів зрілості.

IT: ланцюги постачання, код і хмари

ПРИКЛАДИ ЗАГАЛЬНИХ РОЗВІДУВАЛЬНИХ ВИМОГ ГАЛУЗІ (GIR)

01 Які пакети й залежності з npm, PyPI та інших реєстрів, якими користуються учасники, скомпрометовано за 30 днів?

02 Які техніки атак на CI/CD і репозиторії коду застосовували проти IT-компаній регіону за останні 6 місяців?

03 Які групи атакували українських IT-постачальників і MSP як шлях до клієнтів КІ за останній рік і як?

04 Які техніки атак на AWS, Azure і GCP активно використовували за останній квартал — і що стосується нашої архітектури?

05 Чи були за пів року спроби найняти підставних «IT-фахівців» в українських компаніях і за якими ознаками їх виявили?

Окремо – постачання й хмари

- Скомпрометовані пакети
- Атаки на CI/CD і репозиторії
- Моделювання загроз у мультихмарі
- Згодом — контекст клієнтів

ДЛЯ ПРАВЛІННЯ

Чи не станемо ми точкою входу до клієнтів — і чим це загрожує контрактам?

Плюс базові продукти всіх трьох рівнів зрілості.

ДОДАТОК · ЕНЕРГЕТИКА

Енергетика: загрози для SCADA й АСУ ТП

ПРИКЛАДИ ЗАГАЛЬНИХ РОЗВІДУВАЛЬНИХ ВИМОГ ГАЛУЗІ (GIR)

01 Які групи атакували енергетичні компанії України за останні 12 місяців і які техніки проти OT застосовували?

02 Яке шкідливе ПЗ для SCADA й промислових протоколів виявляли в Україні та Європі за останній рік?

03 Які вразливості контролерів і HMI, що є в учасників, експлуатувались або мали публічний експлойт за 30 днів?

04 Чи з’являлися облікові дані чи доступи підрядників OT учасників у продажу або витоках за останній квартал?

05 Чи передували кібератаки фізичним ударам по енергооб’єктах за пів року і які ознаки підготовки можна було помітити?

Окремо — SCADA й АСУ ТП

- Бюлетень вразливостей промислового обладнання
- Індикатори й детекти для OT-мереж
- Розбори атак на промислові системи

ДЛЯ ПРАВЛІННЯ

Що може зупинити генерацію чи постачання — і що захищати першим?

Плюс базові продукти всіх трьох рівнів зрілості.

Що вирішує успіх ISAC

Довіра понад усе
Прозорість і передбачуваність; довіру будують свідомо.

Статут від учасників
Самі учасники його приймають і регулярно переглядають.

Почати з малого
Робочий ISAC будують роками — терпіння й послідовність.

Берегти час учасників
Секретаріат бере на себе зустрічі, платформу й матеріали.

Живе спілкування
Неформальні зустрічі будують довіру не гірше за правила.

Зручна захищена платформа
Інакше онлайн-обмін просто не приживеться.

Джерело: ENISA ISAC in a Box, Recommendations

ПРИКЛАД · ТЕЛЕКОМ · ГРУДЕНЬ 2023

Найбільший оператор — без зв’язку

Березень 2023
Перші спроби проникнення, за даними СБУ; атаку приписують Sandworm

~9 місяців у мережі

12 грудня 2023
Удар по ядру мережі: ~24 млн абонентів без зв’язку

До 58 годин
Поступово повертається мобільний інтернет

Січень 2024
Безкоштовний місяць для абонентів — 3,6 млрд ₴

~24 млн
абонентів без зв’язку

≈ 40 %
інфраструктури знищено

до 5 млрд ₴
загальні втрати, за оцінками

Публічно: «дані абонентів не витекли». Технічних деталей для інших операторів оприлюднено небагато.

Джерела: DOU: Якою була атака на «Київстар» · Українська правда: проникли ще навесні — СБУ

ПРИКЛАД · ДЕРЖСЕКТОР · ГРУДЕНЬ 2024

Місяць без державних реєстрів

19 грудня 2024
Атака на НАІС — оператора реєстрів Мін’юсту; зупинилися послуги в «Дії»

+11 днів
Нотаріуси знову працюють із ключовими реєстрами

≈ +1 місяць
Відновлено всі реєстри Мін’юсту

Без послуг у «Дії»: акти цивільного стану, ЄДР, послуги для ФОП

Відповідальність узяло XakNet Team; заяви про знищені дані не підтверджено

Публічно: «дані збережено, витоку немає». Технічних уроків для інших організацій публічно не оприлюднено.

Джерела: DOU: Мін’юст відновив роботу реєстрів · Факти: терміни відновлення реєстрів

ЩО ПОЧИТАТИ

Джерела

ХТО	ЩО ПОЧИТАТИ
CI-ISAC	Info Sharing Guidelines · Prospectus · Membership · Benefits
ENISA	ISAC in a Box · Recommendations
США · ISAC	National Council of ISACs · ISAO FAQ · MS-ISAC
США · право	CISA 2015 · DOJ і FTC про антимонопольні ризики
Економіка	DOU: зарплати Security · ціни джерел (UnderDefense) · CTI Use Cases
Практика CTI	Kraven Security · CTI-CMM · STIX/TAXII · TLP 2.0 · MITRE ATT&CK
Опитування	SANS CTI Survey 2026
Кейси	«Київстар» · реєстри Мін’юсту
Україна	Закон про основні засади кібербезпеки · CTI101 — вступ до розвідки